REPÚBLICA PORTUGUESA | PRESIDÊNCIA DO CONSELHO DE MINISTROS

GNS
Gabinete Nacional de Segurança
PORTUGAL

MANUAL

DO

CURSO DE INTRODUÇÃO À SEGURANÇA DA INFORMAÇÃO CLASSIFICADA

(CISIC)

Classificação	Data	Versão do documento
<Não Classificado>		v.1.1

Título
Manual do Curso de Introdução à Segurança da Informação Classificada

Origem
DF/GNS – Doutrina e Formação

Elaborado	Verificado	Aprovado
DF/GNS	DF/GNS Cor Paulo Silva	

Data	Data	Data

Histórico de Versões

Versão	Data	Revisor	Comentários/Notas
V.1.0			Versão Inicial
V.1.1	26/01/2021	COR. N.Azevedo	Versão revista

ÍNDICE

1. Título. 3
2. Finalidade 3
3. Âmbito 3
4. Introdução ao Curso 4
5. Módulo 1 - A INFORMAÇÃO CLASSIFICADA (IC) 5
6. Módulo 2 - A SEGURANÇA DO PESSOAL 3
7. Módulo 3 - A SEGURANÇA FÍSICA 3
8. Módulo 4 - A SEGURANÇA DA INFORMAÇÃO 3
9. Módulo 5 – A SEGURANÇA DOS SISTEMAS DE INFORMAÇÃO E COMUNICAÇÃO 4
10. Módulo 6 – A SEGURANÇA INDUSTRIAL E OS CONTRATOS CLASSIFICADOS 6
11. Bibliografia 6

1. **Título.** Curso de Introdução à Segurança da Informação Classificada.

2. **Finalidade.** Apresentar os conteúdos do Curso de Introdução à Segurança da Informação Classificada em formato e-learning, onde são expostos os princípios e as normas gerais, destinadas a garantir a segurança da Informação Classificada (IC), contra ações intencionais, como por exemplo roubo, dano ou espionagem, e minimizar as falhas humanas suscetíveis de ocasionar comprometimentos e quebras de segurança.

   Pretende constituir uma base de conhecimentos essenciais para o desempenho de funções, em órgãos de segurança em território Nacional e no Estrangeiro.

   Contribui para dar a compreender, a importância da proteção e segurança da informação classificada a quem se relaciona, de uma forma pessoal ou institucional, com material classificado, constituindo a referência base dos frequentadores da formação.

   Constitui pré-requisito para a frequência de formações presenciais e obtenção/renovação de credenciações de segurança.

3. **Âmbito.** Este curso é organizado e realizado pelo Gabinete Nacional de Segurança (GNS), destinando-se a todos os cidadãos nacionais ou estrangeiros que dominem a língua portuguesa e que prestem serviço em Organismos do Estado ou Empresas Portuguesas, que necessitam ou estejam interessados em conhecer os princípios básicos que regem a Segurança da Informação Classificada.

   Destacam-se todos os trabalhadores em funções públicas ou de estado, de forma a garantir a proteção da informação classificada, no âmbito do serviço público ou representativo que prestam em nome do Estado Português.

4. Introdução ao Curso

Os desafios colocados à preservação e segurança da informação classificada nunca foram tão altos como na atualidade. O mundo digital e a facilidade crescente na partilha de informação, nomeadamente a que possa ser considerada como sensível, colocam a atenção dada ao seu manuseamento num nível consideravelmente elevado.

Todos os Estados democráticos são vulneráveis a ações que procuram obter o conhecimento antecipado da informação sobre as suas capacidades nos campos político, económico, científico, tecnológico ou administrativo, com o objetivo de prejudicar, influenciar ou impedir o normal funcionamento das suas instituições.

Portugal não é exceção e também se confronta com estas ameaças, que podem pôr diretamente em causa a sua segurança.

Nestas circunstâncias, o modelo adotado, em que a Autoridade Nacional de Segurança (ANS) é a única entidade responsável, vai ao encontro da necessidade de salvaguarda e proteção da Informação Classificada manifestada pela Organização do Tratado do Atlântico Norte e pela União Europeia, permitindo a necessária uniformidade de procedimentos, de critérios e de direção, bem como a capacidade para auditar o ciclo de vida desta Informação, que são atributos considerados fulcrais para assegurar o cumprimento do princípio da confiança nos processos de gestão da IC, credenciação de pessoas e acreditação de sistemas classificados.

Sabe como a informação sensível pode ser classificada? Conhece as medidas apropriadas para o seu manuseamento em segurança? Tem ideia das ações para a sua proteção em função do grau de classificação atribuído?

É neste pressuposto que a presente formação se enquadra, contribuindo para dar a compreender, de forma atrativa, dinâmica e interativa, a importância da proteção e segurança da informação classificada a quem se relaciona, de uma forma pessoal ou institucional, com matérias classificadas.

5. Módulo 1 - A INFORMAÇÃO CLASSIFICADA (IC)

Tópico 1.1. Definições e conceitos gerais sobre Informação Classificada.

O que é Informação Classificada (IC);

Quais as Marcas e Graus de segurança da IC;

Quais os requisitos para aceder à IC;

Quais as principais ameaças, quebras de segurança e comprometimentos à IC;

O Fator Humano.

Comecemos então o nosso caminho por este universo da Segurança da Informação Classificada…

Poderemos dizer que a Informação Classificada, que doravante designaremos por IC, é toda a informação cujo conhecimento ou divulgação por pessoas não autorizadas pode implicar consequências danosas para a Nação ou nações aliadas ou organizações de que Portugal faça parte.

Toda a IC deverá estar obrigatoriamente assinalada e identificada com um GRAU e de uma MARCA de segurança, uma temática que desenvolveremos mais à frente no Módulo 3 relativo à Segurança da Informação.

Um ponto fundamental que convém referir é o de que, somente poderão ter acesso a IC as pessoas habilitadas com a devida credenciação de segurança, que estejam devidamente informadas das suas responsabilidades para aceder a essa informação e que tenham a necessidade de a conhecer. O cumprimento destas três regras é fundamental. Esta temática será desenvolvida no próximo módulo, Segurança do Pessoal.

Poder-se-ia pensar que as responsabilidades de segurança estariam somente atribuídas a quem tem a responsabilidade pela segurança dentro de uma determinada organização. Nada mais errado… As responsabilidades de segurança não são exclusivas dos responsáveis pela segurança.

A Todo o pessoal de uma organização, aos vários níveis, sejam técnicos, administrativos ou auxiliares cabem responsabilidade neste campo, sem o que não será possível estabelecer um sistema de segurança que funcione eficazmente. Pode-se dizer que a segurança da IC é uma responsabilidade individual que contribui para a segurança coletiva da organização.

A existência clara das competências e da organização funcional da segurança obriga à existência de canais para acionamento das ações relativas à salvaguarda e defesa da IC.

Esta deverá ser convenientemente protegida contra indiscrições, fugas, violações ou descuidos, através de medidas de segurança nas suas principais vertentes:

a) A Segurança do Pessoal;
b) A Segurança Física;
c) A Segurança da Informação;
d) A Segurança dos Sistemas de Informação e Comunicação;
e) e a Segurança Industrial e os contratos classificados.

De todos os princípios aplicáveis, que poderão consultar na área de recursos, vamos apenas abordar aqueles que consideramos como transversais na proteção da IC:

São eles:

A Necessidade de conhecer – como já referimos, o acesso às matérias classificadas deve restringir-se, exclusivamente, às pessoas que tenham necessidade de as conhecer para cumprimento das suas funções ou tarefas;

E a **Importância do fator humano**- Nunca será demais referir que por mais rigorosas que sejam as medidas de segurança física e de manuseamento de documentos, estas não serão totalmente eficazes se não tiverem em conta a importância do fator humano. Esta circunstância envolve a avaliação contínua da idoneidade do pessoal autorizado a manusear IC e ainda a conjugação daquelas medidas com a proteção obtida através de revistas, rondas, vigilância e inspeções, executadas por pessoal credenciado e devidamente preparado para o efeito;

Tópico 1.2. Situações de comprometimento e de quebra de segurança

Comprometimento ou quebra de segurança da Informação Classificada, o que é;

Medidas de proteção para evitar comprometimentos e quebras de segurança mais comuns. Exemplos práticos: No seu manuseamento; guarda, arquivo, transporte e destruição (locais trabalho, impressoras, fotocopiadoras, webmail, etc.).

Depois de termos aprendido o que significa Informação Classificada e de termos percebido quem é que lhe pode aceder e compreendido que existem responsabilidades associadas a esse acesso, vamos tentar mostrar de que forma a IC pode ser posta em perigo e como podemos protegê-la.

(Conceitos no âmbito das IC)

Vejamos então o que são:

- **Quebras de segurança** - É toda a ação contrária ou omissa aos regulamentos de segurança em vigor que faça perigar ou possa comprometer as matérias classificadas;
- **Comprometimentos** - É o conhecimento, parcial ou total, de IC por parte de pessoas não autorizadas, isto é, pessoas sem a adequada credenciação ou sem acesso autorizado. Considera-se ter havido comprometimento sempre que as IC tenham estado sujeitas ao risco de divulgação a pessoas não autorizadas ou tenham estado perdidas, ainda que temporariamente.

Face a este tipo de situações, vejamos então quais são as **Medidas gerais para evitar comprometimentos e quebras de segurança mais comuns:**

a) Nas conversas sobre IC – Só são permitidas conversas ou discussões sobre IC na presença de pessoas com necessidade de conhecer, o que pressupõe, a sua prévia credenciação e autorização para acesso. Em conferências, lições, palestras, etc., a assistência deverá ser previamente prevenida do grau de segurança que as IC tratadas exigem, os assistentes serão informados de que lhes é proibido tirar notas ou apontamentos (ou qualquer outro tipo de registo analógico ou digital).
b) Em Publicações – É expressamente proibida a inclusão de IC em qualquer publicação de divulgação pública. Nenhum funcionário está autorizado a facultar em qualquer

c) publicação, IC de que tenha conhecimento. Em caso de dúvida, mesmo que seja o autor, ou a pessoa responsável pela publicação, deve consultar sobre o assunto o seu superior hierárquico.

d) Quanto à saída de IC das instalações do serviço – Nenhum documento classificado poderá ser levado para fora das instalações com a finalidade de ser trabalhado em casa ou por quaisquer outras razões.

e) Quanto à detenção particular de IC – Os funcionários não são autorizados a possuir arquivos particulares, diários ou documentos contendo IC.

E, finalmente,

f) Na utilização de sistemas de comunicação – deverão ser observados os procedimentos e condutas de segurança estabelecidos, que proíbem a utilização dos sistemas e equipamentos não seguros para a transmissão de IC.

6. Módulo 2 – A SEGURANÇA DO PESSOAL

Tópico 2.1. Caraterísticas e medidas da Segurança do Pessoal.

Quais são as principais caraterísticas da Segurança do Pessoal;

O que é a Credenciação de Segurança e o que é que envolve;

Quem precisa de estar credenciado;

Depois de termos abordado os principais conceitos relacionados com a segurança da Informação Classificada, entramos agora no módulo dedicado à Segurança do Pessoal.

Poderemos dizer que a Segurança do Pessoal é materializada na aplicação de medidas que se destinam a garantir que a credenciação para acesso à Informação Classificada (IC), só é concedida a quem cumpra com três condições fundamentais, a saber:

Tenha necessidade de conhecer, possua a credenciação de segurança adequada, por último, tenha sido informado das responsabilidades que lhe cabem.

A Credenciação de segurança pessoal é uma autorização para o manuseamento de IC ao pessoal em serviço que, por força das funções inerentes ao seu cargo, tenha necessidade de a conhecer e/ou manusear.

Isto quer dizer que não permite que o seu titular tenha acesso a toda a IC, mas apenas àquela que, pela natureza das suas funções, tenha necessidade absoluta de conhecer. Daqui ressalta a diferenciação entre credenciação e acesso, sendo que uma não implica necessariamente a outra.

É importante salientar que ninguém está autorizado a ter acesso a IC apenas por força do seu cargo ou credenciação de segurança que possua.

Este princípio aplica-se a todo o pessoal, em todo e qualquer caso. A necessidade de conhecer deverá, pois, ser previamente determinada e constantemente atualizada, não devendo ser atribuído, a quem quer que seja, um grau de credenciação superior àquele que for requerido pela IC a que deva ter acesso.

A credenciação de segurança pessoal é atribuída mediante um processo, relativamente extenso, que visa verificar a idoneidade, lealdade e fiabilidade do indivíduo, tendo em conta os interesses que fundamentam o pedido dessa credenciação. Este processo necessita obviamente do consentimento prévio e expresso do interessado.

Após a conclusão com sucesso do processo de verificação das condições anteriormente descritas, será emitido um certificado de Credenciação correspondente ao grau da IC que o requerente estará autorizado a manusear.

Salientamos que a concessão de todo e qualquer certificado de credenciação Nacional é da exclusiva competência da Autoridade Nacional de Segurança (ANS), não podendo esta competência ser delegada. A ANS é, por inerência de funções, o Diretor-Geral do Gabinete Nacional de Segurança (GNS).

Com já referimos, o grau de credenciação de segurança de cada indivíduo tem de estar em conformidade com o grau máximo de classificação da IC que deva manusear. Em Portugal, é necessária a obtenção prévia de uma credenciação de segurança para os graus de classificação:

- MUITO SECRETO
- SECRETO
- CONFIDENCIAL

assim, os indivíduos ou entidades aos quais esta é atribuída, dizem-se credenciados para MUITO SECRETO, para SECRETO ou para CONFIDENCIAL, conforme os casos.

Por inerência das funções que desempenha, o pessoal que necessite de aceder ou manusear IC de grau RESERVADO não tem necessidade de obtenção prévia de uma credenciação, salvaguardadas que sejam as medidas de segurança estabelecidas para esse grau.

Tópico 2.2. Principais normas da Segurança do Pessoal

Os conceitos associados à Segurança do Pessoal, quanto à necessidade de acesso (necessidade de conhecer), habilitação para aceder e nível de classificação da IC;

O dever de sigilo;

O processo de credenciação.

Como acabámos de ver, os organismos que detenham IC deverão assegurar-se de que todas as pessoas a quem essa informação tenha de ser confiada estão, efetivamente, credenciadas para o seu manuseamento.

Deverão ser elaboradas listas das pessoas credenciadas que poderão ter acesso á IC, por determinado período. Estas listas serão individualizadas para cada grau de classificação e serão submetidas à aprovação dos respetivos Diretores, Comandantes ou Chefes.

Importa referir que, mesmo aqueles que embora não tenham necessidade de aceder a informação classificada, mas que a natureza das suas funções lhes possa proporcionar esse acesso, ainda que involuntário, também deverão ser objeto de credenciação. Nestas situações podemos incluir pessoal auxiliar, de limpeza, porteiros, guardas ou motoristas.

Antes de ter acesso à IC, o pessoal que para tal está credenciado, deve ser instruído, por elementos devidamente habilitados, sobre os procedimentos de segurança a cumprir e sobre as consequências previstas na lei para os casos em que a IC caia em mãos não autorizadas, quer voluntariamente, quer por ato negligente.

É indispensável que tais pessoas sejam advertidas quanto aos perigos que representam para a segurança, as conversas indiscretas, especialmente fora do serviço, as relações com os órgãos de comunicação social e com possíveis agentes dos serviços de informações de outros Estados.

É importante perceber que mesmo para as situações onde não é necessária a obtenção de credenciação, como é o caso do acesso e manuseamento de IC com o grau RESERVADO é imperativa a observação do dever de sigilo.

Como já referimos, a Credenciação de Segurança Pessoal (CSP) implica um processo de credenciação, pelo que as entidades públicas ou privadas que tenham necessidade de credenciar os seus funcionários ou colaboradores devem fazer o respetivo pedido à Autoridade Nacional de Segurança (ANS) que, como vimos, é a única autoridade competente para esse efeito.

Este processo é desencadeado pelos próprios, cidadãos, empresas ou entidades públicas, utilizando a plataforma de Credenciações de Segurança, CRESO, alojada na página do GNS e cujos detalhes para acesso poderão ser encontrados na documentação anexa a este curso.

Todavia, e em caso de impossibilidade ou necessidade imperiosa poderá recorrer-se ao envio diretamente à ANS, pela entidade proponente, da documentação necessária que também se encontra disponível na página do GNS.

Após a receção dos documentos, o Gabinete Nacional de Segurança (GNS) inicia um processo com vista a determinar se o requerente reúne as condições para a concessão da credenciação solicitada. Neste processo, a lealdade, a idoneidade e a fiabilidade, são requisitos indispensáveis e serão aferidos por meio de um inquérito de segurança, cujos resultados são avaliados pela ANS.

Em resultado do inquérito de segurança, e no caso de existir um despacho favorável da ANS, o GNS emite um Certificado de Credenciação de Segurança Pessoal (CCSP) que envia à entidade proponente.

Este inquérito de segurança abrange pelo menos os últimos dez anos ou o período compreendido entre os 18 anos de idade e o momento presente.

Sem prejuízo de outras circunstâncias atendíveis, os critérios a ter em conta para determinar se uma pessoa preenche ou não os requisitos referidos irão aumentar em função do grau de credenciação que se pretende obter, sendo analisados caso a caso.

Em caso de necessidade, podem ser efetuadas investigações adicionais para aprofundar todas as informações pertinentes de que se disponha, nomeadamente entrevistas pessoais ou com terceiros que estejam em condições de fazer uma avaliação imparcial da pessoa objeto da credenciação.

A CNPD autoriza a Autoridade Nacional de Segurança/GNS ao tratamento de dados pessoais com a finalidade de Credenciação de Segurança de pessoas singulares (Autorização n.º 6323/2012 da CNPD).

Todas as credenciações, nacionais ou internacionais têm um prazo de validade associado. Findo o prazo de validade ou mesmos durante esse período, caso as razões que deram origem à sua emissão sofram alterações, as credenciações poderão ser revalidadas, reavaliadas (para alterar o seu grau) ou até mesmo canceladas.

Qualquer destas situações dará origem a um novo processo, idêntico ao que deu origem à credenciação inicial, que culmina com a emissão de um novo Certificado de Credenciação.

7. Módulo 3 - A SEGURANÇA FÍSICA

Tópico 3.1. Caraterísticas da Segurança Física

O que se entende por segurança física;

Quais são os requisitos e os princípios associados à Segurança Física;

Depois de temos abordado o tema da Segurança do Pessoal, falemos então de Segurança física.

Poderemos dizer que é a parte da segurança que se preocupa com as medidas físicas destinadas a salvaguardar o pessoal e prevenir acessos não autorizados a informações, materiais e instalações, contra a espionagem, sabotagem, vandalismo e roubo, tanto nos locais e durante deslocações.

Estas medidas deverão ser concebidas tendo em vista alcançar os seguintes objetivos:

a) Impedir qualquer intrusão de pessoal de forma não autorizada nas áreas ou dependências onde são guardadas IC;

b) Desencorajar, impedir e detetar ações de elementos desleais, suscetíveis de atuar ilegalmente;

c) Restringir o acesso á IC ao pessoal, segundo o princípio da necessidade de conhecer;

E, finalmente,

d) Assegurar, em todas as circunstâncias, o perfeito controle quer da própria IC quer dos dispositivos ou equipamentos usados tais como chaves e combinações de segredo dos dispositivos de segurança que permitam o acesso à IC.

Como se deve calcular, independentemente do cumprimento das regras estabelecidas e dos requisitos normativos, os locais onde existem IC são muito diversificados de acordo com a sua dimensão, localização e quantidade e grau de IC processada.

Para podermos decidir qual o grau de proteção física a adotar em função das características da IC é necessário ter em conta os elementos em causa, a saber:

a) Qual o grau de classificação e a natureza da informação a proteger;

b) Qual o volume e o tipo das matérias a salvaguardar;
c) Que a habilitação de segurança e a necessidade de conhecer do pessoal está claramente definida;

E, por último,

d) Quanto ao resultado da avaliação das ameaças constituídas pelos serviços de informações hostis, atividades terroristas e criminosas;

Tópico 3.2. Principais medidas

Perímetros de segurança, principais caraterísticas;
Áreas de segurança, descrição;
Implementação das medidas de acordo com princípio da "defesa em profundidade";
Planos de emergência, evacuação e destruição;

Depois de termos abordado os conceitos gerais ligados à segurança física, vejamos então quais são a principais medidas a aplicar.

A segurança física efetiva é alcançada por várias camadas das diferentes medidas, o que chamamos de 'defesa em profundidade'. O conceito é baseado no princípio de que a segurança não é significativamente reduzida com a perda de uma única camada. Cada camada de segurança pode ser composta de diferentes elementos, incluindo:

a) Perímetros de segurança (áreas exteriores dos edifícios e áreas interiores)
b) Áreas de segurança;
c) Sistemas de controlo de acessos;
d) Sistema de deteção de intrusão;
e) Sistema de videovigilância;
f) Contentores ou móveis de segurança, casas-fortes, fechaduras e cadeados;
g) Pessoal de segurança e rondas;
h) Controlo das chaves e combinações;
i) Proteção contra a espionagem (vistas e escuta);
j) Verificação de áreas tecnicamente seguras;
k) Verificação técnica de equipamentos de telecomunicações e equipamentos elétricos e eletrónicos, de qualquer tipo.

Estas medidas são interdependentes e sua eficácia será ditada pela capacidade de apoiar-se mutuamente. Por esse motivo, recomendamos que todas as medidas de segurança sejam desenvolvidas após um processo de gestão e avaliação de riscos e vulnerabilidades.

Deverá ser ainda ser prevista a existência de Planos de Evacuação e destruição de emergência que deverão ser treinados e revistos com frequência.

8. Módulo 4 – A SEGURANÇA DA INFORMAÇÃO (ciclo de vida da IC)

Tópico 4.1. Objetivos e princípios da Segurança da Informação Classificada

Identificação dos objetivos e princípios mais relevantes;

Confidencialidade, Integridade, Disponibilidade, Autenticidade, Não Repúdio, Responsabilização;

A gestão da informação classificada pressupõe a aplicação de medidas administrativas de controlo ao longo do seu ciclo de vida que visam complementar as restantes medidas já mencionadas ao longo desta formação.

Estas medidas deverão, sobretudo, estabelecer procedimentos para produção, registo, reprodução, arquivo, reclassificação (entenda-se abaixamento do grau), desclassificação e destruição de IC;

Como parte do processo de gestão, a IC é registada antes da distribuição e no momento da receção. Para esse efeito, as entidades deverão de utilizar o sistema de registo e controlo, Sistema de Segurança Eletrónica da Informação (SEIF), aprovado pela ANS ou um formato de registo manual que terá em conta o grau de classificação da IC como iremos ver mais adiante.

Noutra vertente, os serviços e instalações onde se proceda ao manuseamento ou armazenamento de IC, terão de ter implementadas as medidas de segurança física já apresentadas no módulo 3 desta formação e deverão ser submetidas a inspeções periódicas por parte da ANS.

Todas as pessoas que trabalham e colaboram no processo de gestão da IC devem estar devidamente habilitadas (credenciadas) de acordo com o grau e a marca de segurança das IC aí tratadas e deverão ter necessidade de conhecer a IC.

> *"O acesso à informação classificada só deverá ser autorizado às pessoas que dela necessitem tomar conhecimento para o desempenho das suas funções ou tarefas";*
>
> *"A responsabilidade por determinar a necessidade de conhecer incumbirá ao serviço no qual a pessoa em questão desempenha funções";*

"O acesso à informação classificada de qualquer marca e grau CONFIDENCIAL, equivalente ou superior, só será autorizado a pessoas que tenham a habilitação de segurança adequada (credenciação de segurança)";

Outro aspeto que importa referir é que quando a IC é transmitida por meios eletrónicos ou transportada em suporte eletrónico, quer sejam, dispositivos USB, CD ou discos rígidos, deve estar protegida por produtos criptográficos aprovados pela ANS como iremos referir no módulo da Segurança dos Sistemas de Informação e Comunicação.

Em resumo, poderemos acrescentar que um processo de gestão da IC eficaz deverá garantir:

A sua Confidencialidade, assegurando que a informação seja acessível apenas àqueles autorizados a ter acesso

A sua Integridade, garantindo que a informação não foi alterada de forma não autorizada ou indevida.

A sua Disponibilidade, por forma a que a informação esteja sempre disponível para os utilizadores autorizados

A sua Autenticidade, atestando que a informação é proveniente da fonte anunciada e que não foi alvo de mutações ao longo de um processo

e…

O Não repúdio, ou seja, a possibilidade de identificação inequívoca da sua origem (Responsabilização).

Tópico 4.2. O ciclo de vida da informação classificada, medidas e normas de segurança

A produção, registo, reprodução, transferência, arquivo, reclassificação, desclassificação e destruição de IC;

Os órgãos de gestão da Informação Classificada;

Transmissão da IC por correio, ou pessoa habilitada;

Iremos agora, na segunda parte deste módulo, e de uma forma sucinta, falar-vos dos principais procedimentos a seguir durante a "Classificação, preparação e manuseamento de documentos classificados".

Neste tópico recomendamos a consulta dos Cap. 3 - Classificação de Segurança e Cap. 6 - Classificação e preparação de documentos, do SEGNAC1, assim como as Normas Técnicas do GNS, NT - E 01 - Marcas, Graus de Segurança e Designadores.

Como já foi mencionado, a informação classificada caracteriza-se pelo grau e marca de segurança.

Marca	NACIONAL	NATO	UE
Grau	**MUITO SECRETO**	**COSMIC TOP SECRET**	**TRÉS SECRET UE**
	(MS)	(CTS)	(TS-UE/EU-TS)
	SECRETO	**NATO SECRET**	**SECRET UE**
	(S)	(NS)	(S-UE/EU-S)
	CONFIDENCIAL	**NATO CONFIDENTIAL**	**CONFIDENTIEL UE**
	(C)	(NC)	(C-UE/EU-C)
	RESERVADO	**NATO RESTRICTED**	**RESTREINT UE**
	(R)	(NR)	(R-UE/EU-R)

As entidades com competência para atribuir uma classificação de segurança devem, perante casos concretos, verificar se se justifica a sua atribuição e, em caso afirmativo, escolher criteriosamente o grau adequado.

Uma vez classificada a informação, haverá que determinar o conjunto de medidas de segurança de que a mesma deve beneficiar durante o seu ciclo de vida

e designar as pessoas que, pelas suas funções, tenham necessidade de a manusear e ou dela tomar conhecimento, que deverão estar devidamente credenciados.

A estrutura de segurança implementada nas organizações terá como missão garantir a segurança da informação, pelo que o envolvimento da gestão de topo, comando, direção ou chefia é fundamental, sendo a verificação da execução das normas uma responsabilidade permanente.

Por esse motivo, todos os organismos que tenham IC sob a sua responsabilidade devem possuir um sistema de gestão documental em conformidade com o estabelecido pelas normas técnicas da ANS.

É fundamental a existência de um sistema de registo e controlo de IC que, de uma forma geral deverá conter os elementos essenciais que permitam a identificação individual e inequívoca da IC:

a) Número de registo de entrada;

b) Data do documento;

c) Referencia do documento (sigla);

d) Título do documento;

e) Classificação de segurança do documento;

f) Número de exemplar e/ou copia;

g) Data de receção do documento;

h) Localização do documento;

i) Data de destruição do documento e número do certificado de destruição.

No âmbito da Reprodução, transferência e destruição de documentos classificados, recomendamos a consulta do Cap. 7 do SEGNAC1, a consulta da Norma Técnica E-03 - Transferência da informação classificada e a consulta da Norma Técnica -E09 – Gestão da informação classificada.

Também para a reprodução e cópia da IC, quando autorizadas, estão definidos procedimentos muito claros, associados ao seu grau de classificação, sendo o registo, controlo e inventário obrigatórios para os graus mais elevados e obrigatória a indicação de forma visível, em todos os exemplares reproduzidos, da classificação do documento original.

Para a transferência e transporte de IC deve ter-se presente, como princípio obrigatório, que este só deve ser confiado a pessoas credenciadas com o grau correspondente ou utilizarem-se Sistemas de Informação e Comunicação (SIC) acreditados. Como iremos desenvolver no módulo 5.

Tendo em vista evitar acumulações desnecessárias, O ciclo de vida da IC termina com a destruição periódica e logo que conveniente de todos os documentos já substituídos ou que se presuma não haver necessidade de preservar.

É evidente que o bom senso deverá presidir, em cada caso, à decisão da oportunidade de destruição; todavia, deverá evitar-se manter em arquivo documentos classificados com mais de cinco anos cuja necessidade ou interesse histórico não seja reconhecido.

Quer os procedimentos a ter para a destruição de IC em segurança, quer os prazos mínimos para a retenção dos respetivos registos poderão ser consultados na legislação aplicável disponível na área de recursos.

Como nunca é demais salientar, recordamos o papel do fator humano no processo que gere o ciclo de vida da IC, pelo que aspetos como usar e cumprir com a regulamentação aplicável, proteger ativamente o uso e a guarda da documentação classificada, a utilização de passwords, Internet e equipamentos móveis, são de fundamental importância.

9. Módulo 5 – A SEGURANÇA DOS SISTEMAS DE INFORMAÇÃO E COMUNICAÇÃO (SIC)

Tópico 5.1. Os Sistemas de Informação e Comunicação e a Segurança da Informação

Caraterísticas dos Sistemas de Informação e Comunicação (SIC);
A Garantia da Informação e as suas principais funções;
Validação dos mecanismos e das políticas de segurança;

Por definição, um Sistema de Informação e Comunicações (SIC) permite armazenar, processar e transmitir informação e compreende todos os ativos necessários ao seu funcionamento, designadamente infraestrutura, organização, pessoal e recursos.

A Garantia da Informação (GI)1 está intrinsecamente ligada aos SIC uma vez que representa a confiança com que esses sistemas, eletrónicos e não-eletrónicos, protegem as informações por eles manuseada, durante todo o ciclo de vida, sob o controlo de utilizadores legítimos, assegurando níveis adequados de confidencialidade, integridade, disponibilidade, não repúdio e autenticação.

A natureza dinâmica da segurança obriga a uma revisão contínua dos requisitos associados aos SIC, através de uma abordagem iterativa que permite aplicar controlos de segurança de natureza política, organizacional, processual e técnica, com base na avaliação do risco e na identificação das possíveis vulnerabilidades.

No sentido de compatibilizar a partilha de informação de forma segura e confiável com as limitações de natureza técnica decorrentes da implementação desses controlos é essencial que o planeamento de segurança inclua uma cooperação muito estreita entre os principais responsáveis da organização, os administradores e os oficiais de segurança de cada SIC.

Para além disso, as políticas, os processos, as normas e os controlos devem ser delineados e geridos por forma a que possam ser integrados com as restantes áreas da segurança que temos vindo a abordar, incluindo, quando aplicável, a segurança industrial.

A garantia da Informação pressupõe que os produtos, equipamentos e serviços concebidos para lidar com IC, sejam submetidos a um processo de certificação para aferir da existência das funcionalidades necessárias e de um processo de Acreditação, a fim de garantir que foram tomadas

todas as medidas de segurança adequadas à proteção da IC e do próprio SIC, pelo que esses equipamentos devem estar instalados em áreas de segurança de classe 1 ou classe 2.

Com vista à materialização do processo de acreditação, a Autoridade Nacional de Segurança, no âmbito da Garantia da Informação, é responsável pela definição:

a) de políticas e diretivas de segurança e o controlo da sua eficácia e pertinência;

b) pela salvaguarda e administração da informação técnica e seleção dos produtos criptográficos;

c) pela garantia que as medidas selecionadas estão em consonância com as políticas que regem a elegibilidade e seleção dos produtos, equipamentos e serviços;

d) pela avaliação, certificação e acreditação de SIC no domínio da segurança da IC.

()[1] 2013/488/EU "Decisão do Conselho relativa às regras de segurança aplicáveis à proteção das informações classificadas da UE"– Anexo IV

Tópico 5.2. A Garantia da Informação, princípios

Princípios da Garantia da Informação, (Gestão de risco, eficiência, privilégios mínimos, Necessidade de conhecer, Autoproteção, Defesa em Profundidade, Manutenção atualizada da configuração, Resiliência, Validação dos mecanismos e das políticas de segurança);
O Quadro Nacional de Referência em Cibersegurança;

Depois de termos visto o que se entende por Sistemas de Informação e Comunicação (SIC) e de termos compreendido a sua interligação com a Garantia da Informação (GI), vamos agora mostrar os princípios que regem a implementação das medidas de segurança dos SIC utilizados no manuseamento da IC.

Como já vimos, após a identificação dos potenciais riscos e ameaças, a sua gestão será conduzida como um processo iterativo, seguindo um processo, transparente e plenamente compreensível para todos (proprietários do sistema, as autoridades de projeto, as autoridades operacionais e as autoridades de aprovação de segurança), aplicando as políticas e diretrizes definidas pela Garantia da Informação.

Defesa em Profundidade

O estabelecimento e implementação das medidas de segurança deve resultar de um compromisso satisfatório entre os requisitos do utilizador, os custos, o risco potencial avaliado e o risco residual aceitável pela comunidade de interesse.

Validação dos mecanismos de segurança e políticas de segurança

No processo de Acreditação que daí decorre, serão feitos ensaios de segurança a fim de assegurar o nível de garantia adequado e de verificar se os sistemas estão corretamente implementados, integrados e configurados para o ambiente operacional correto. Este processo incluirá, uma declaração do risco residual aceitável pela gestão de topo da organização.

Postura de segurança

A reanálise da avaliação dos riscos e das vulnerabilidades deverá ser feita periodicamente através de inspeções e análises de segurança e sempre que ocorrerem circunstâncias excecionais, por forma a acompanhar a evolução do ambiente operacional, garantindo a segurança ao longo do ciclo de vida do SIC, desde a sua implementação até à retirada de serviço.

Paralelamente, a documentação de segurança do SIC também deverá evoluir, como parte integrante do processo de gestão da mudança e da atualização da configuração.

Simplificação e Privilégios mínimos

Naturalmente, só serão ativadas as funcionalidades, os dispositivos e os serviços essenciais e os seus utilizadores e processos automatizados só beneficiarão dos acessos, privilégios ou autorizações que forem indispensáveis.

Auto-proteção e Resiliência

Para além disso, todas as interconexões de um SIC com outros sistemas informáticos obedecerão aos requisitos mandatórios, que, por exemplo, proíbem a interconexão entre SIC acreditados para manusear IC e redes desprotegidas ou públicas, possuindo a automação necessária para se recuperarem de qualquer tipo de falha ou avaria de forma a assegurar a continuidade das operações.

Voltando a reforçar a importância do fator humano, a fim de assegurar uma boa perceção das responsabilidades em matéria de segurança, os cursos de formação e sensibilização para a segurança dos SIC terão de ser obrigatórios para todo o pessoal envolvido, incluindo os funcionários que ocupem lugares de direção e todos os utilizadores.

Finalmente, a Autoridade Nacional de Segurança, através do Centro Nacional de Cibersegurança, certificar-se-á de que são implementadas capacidades para responder a ciber-ameaças suscetíveis de ultrapassar as fronteiras da organização.

As respostas são coordenadas sendo as informações sobre essas ameaças e incidentes e os riscos deles resultantes partilhados no âmbito do Quadro Nacional de Referência para a Cibersegurança[1].

()[1] https://www.cncs.gov.pt/content/files/cncs_qnrcs_2019.pdf

10. Módulo 6 – A SEGURANÇA INDUSTRIAL E OS CONTRATOS CLASSIFICADOS

Tópico 6.1. Definições, conceitos, aplicação.

Área de responsabilidade e incidência da Segurança Industrial, Núcleos de Segurança e Encarregado de Segurança;

Este módulo é exclusivamente dedicado à Segurança Industrial (SI) que compreende os princípios e a determinação de normas destinadas à aplicação das medidas de segurança da Informação Classificada (IC), a ter em conta pelos estabelecimentos, empresas, organismos ou serviços das áreas industrial, tecnológica ou de investigação, no âmbito de negociações e durante as atividades que desenvolvam ao abrigo de contratos classificados, como, por exemplo:

- Quando pretendam concorrer a concursos públicos classificados (Nacionais e Internacionais;
  ou
- Quando são prestadores de serviços, de produção de bens e de investigação que exigem o acesso, posse e controlo de IC;
  ou ainda
- Quando se dedicam à Importação / produção / comercialização de bens e tecnologias militares.

A salvaguarda e a proteção da IC, presente sob qualquer forma, será sempre da responsabilidade das respetivas presidências, direções ou chefias. Ao Gabinete Nacional de Segurança competirá, através de ações de coordenação, credenciação, inspeção e atuação técnica, a verificação do cumprimento dos regulamentos e regras aplicáveis à proteção da IC e ao funcionamento pleno de todo o edifício protetivo correspondente.

Na legislação nacional aplicável[1], encontra-se prevista a constituição de Núcleos de Segurança, chefiados por um Encarregado de Segurança, com a finalidade de tratar de todos os aspetos inerentes à implementação e manutenção das medidas para a segurança da informação classificada.

Para tal, como responsável por planear, coordenar e executar as medidas necessárias, o Encarregado de Segurança deverá ter preparação para ser o principal conselheiro da direção em todos os assuntos de segurança.

()[1] SEGNAC2

Artigo 37.º Encarregado de segurança

Artigo 36.º Núcleos de segurança

Anexo I – Glossário de termos técnicos de segurança

Tópico 6.2. Requisitos associados à Segurança Industrial.

Funções e responsabilidades do Encarregado de Segurança;

A credenciação de empresas;

O Posto de Controlo.

Pelo que anteriormente foi referido, podemos dizer que o papel do Encarregado de Segurança é essencial para o desenvolvimento de uma cultura de segurança dentro da organização, devendo envolver os principais departamentos, como por exemplo, a Tecnologia da Informação e os Recursos Humanos.

Em organizações de maior dimensão, este trabalho poderá ser realizado com o apoio de outros elementos, dedicados a áreas muito específicas como é o caso do CISO (Chief Information Security Officer) ou o DPO (Data Protection Officer), responsáveis, respetivamente pela infraestrutura e sistemas informáticos e pela proteção de dados.

Para tal, deverá desenvolver a sua atividade em permanente e estreita ligação com o GNS, o qual lhe prestará todo o apoio relativamente às medidas obrigatórias que serão necessárias implementar em cada uma das áreas.

À semelhança das credenciações pessoais, a credenciação de uma empresa, como pessoa coletiva, é conferida através da credenciação nominal da(s) pessoa(s) que obriga(m) juridicamente a empresa, os seus administradores ou sócios-gerentes.

Este processo compreende a implementação e adequação de todas as infraestruturas e a constituição de um órgão de segurança designado por Posto de Controlo[1], dotado dos requisitos exigidos com vista a uma adequada proteção e salvaguarda da informação classificada (em suporte físico ou lógico), e, para isso, as medidas de segurança a implementar deverão estar em conformidade com o referido no módulo 3.

A verificação / confirmação do cumprimento desses requisitos é assegurada através de uma inspeção do Gabinete Nacional de Segurança, como condição obrigatória para a abertura do Posto de Controlo da empresa e da respetiva credenciação.

O GNS certifica-se que a empresa implementou um programa de segurança protetiva, cumprindo os normativos NACIONAIS, NATO e UE, incluindo o estabelecimento de procedimentos

relacionados com visitas nacionais ou estrangeiras e o transporte nacional e internacional de informação classificada.

Após verificado o cumprimento dos normativos vigentes, a Autoridade Nacional de Segurança concederá a credenciação, quer à empresa quer aos seus quadros que necessitem de aceder à informação classificada, não esquecendo, como é óbvio, o Encarregado de Segurança.

Terminamos assim o último dos módulos da presente formação, encorajando-o(a) a consultar toda a documentação disponibilizada, no sentido de aprofundar os seus conhecimentos, quer seja sobre o conteúdo de um tópico ou um tema específico que aqui foi apresentado.

()[1] NT-E06-Registo Central Sub-registos Postos Controlo.

11. **BIBLIOGRAFIA** (https://www.gns.gov.pt/legislacao.aspx)

Nacional

Resolução do Conselho de Ministros n.º 50/88, 03DEZ88 - SEGNAC 1

Resolução do Conselho de Ministros n.º 37/89, 24OUT89 - SEGNAC 2

Resolução do Conselho de Ministros n.º 16/94, 22MAR94 - SEGNAC 3

Resolução do Conselho de Ministros n.º 5/90, 28FEV90 - SEGNAC 4

Normas Técnicas da ANS - Registo Central

Norma Técnica GNS - NT G-01 - Prazos de Validade e de Renovação de Credenciações (03JAN2020)

Norma Técnica GNS - NT C-01 - Atribuições de um encarregado de segurança de uma empresa credenciada

Norma Técnica GNS - NT-E06 - Registo Central Sub-registos Postos Controlo.

NATO

C-M(2002)49 Security within NATO dated 10 September 2004

AC-35-D/2000-REV7 Directive on Personnel Security.

AC-35-D/2001-REV2 Directive on Physical Security.

AC-35-D/2002-REV4 Directive on the Security of Information.

AC/35-D/2002 *"Directive on the Security of Information"*

AC-35-D/2004-REV3 Primary Directive on CIS Security.

AC-35-D/2005-REV2 INFOSEC Management Directive for CIS

AC/35-D/2003-REV5, 13mai2015 - *Directive on Classified Project and Industrial Security*

União Europeia (UE)

Decisão 2013/488/EU "Decisão do Conselho relativa às regras de segurança aplicáveis à proteção das informações classificadas da UE "

Decisão (UE, Euratom) 2015/444 da Comissão, 13mar2015;